

# Vulnerabilities Report

## 1. Session Management Response Identified

**Description:** The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.

### Tags:

**Risk:** Informational

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 2. Cookie No HttpOnly Flag

**Description:** A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.

### Tags:

CWE-1004

OWASP\_2021\_A05

WSTG-v42-SESS-02

SYSTEMIC

OWASP\_2017\_A06

**Risk:** Low

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 3. Cookie without SameSite Attribute

**Description:** A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.

### Tags:

OWASP\_2021\_A01  
WSTG-v42-SESS-02  
SYSTEMIC  
CWE-1275  
OWASP\_2017\_A05

**Risk:** Low

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 4. Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)

**Description:** The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.

### Tags:

OWASP\_2021\_A01  
WSTG-v42-INFO-08  
SYSTEMIC  
OWASP\_2017\_A03  
CWE-497

**Risk:** Low

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 5. Missing Anti-clickjacking Header

**Description:** The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

### Tags:

OWASP\_2021\_A05  
CWE-1021  
SYSTEMIC  
WSTG-v42-CLNT-09  
OWASP\_2017\_A06

**Risk:** Medium

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 6. Absence of Anti-CSRF Tokens

**Description:** No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf. CSRF attacks are effective in a number of situations, including: \* The victim has an active session on the target site. \* The victim is authenticated via HTTP auth on the target site. \* The victim is on the same local network as the target site. CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.

### Tags:

OWASP\_2021\_A01

SYSTEMIC

WSTG-v42-SESS-05

OWASP\_2017\_A05

CWE-352

**Risk:** Medium

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 7. User Agent Fuzzer

**Description:** Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.

### Tags:

SYSTEMIC

**Risk:** Informational

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET

## 8. Content Security Policy (CSP) Header Not Set

**Description:** Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

### Tags:

OWASP\_2021\_A05

SYSTEMIC

CWE-693

OWASP\_2017\_A06

**Risk:** Medium

**URL:** [http://192.168.56.101/dvwa/vulnerabilities/xss\\_r/](http://192.168.56.101/dvwa/vulnerabilities/xss_r/)

**Method:** GET